

Security+ 2.2 · Phishing

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.2 — Phishing (6:32)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Fraude por email: phishing em massa; Spear phishing = alvo específico com contexto pessoal; Whaling = mirando EXECUTIVO (a baleia); Vishing = por voz (ligação); SMiShing = por SMS. Defesa: MFA, antispam, SPF/DKIM/DMARC (autentica o remetente), awareness.

Highlights que a prova cobra

- Whaling = phishing mirando executivo (spear phishing de whale)
- Vishing = phishing por VOZ; SMiShing = por SMS
- SPF/DKIM/DMARC: o trio de autenticação de remetente de email

Dicas de prova & Cenários Típicos

- 'C-level executives target' = whaling
- 'phishing by voice call' = vishing

Cenário clássico de exame: Cenário típico: 'email urgente se passando pelo CFO pedindo transferência' = whaling/BEC — não phishing genérico.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.2 — Phishing)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **DKIM:** DomainKeys Identified Mail: Assina digitalmente o cabeçalho e corpo de e-mails usando a chave privada do domínio remetente, permitindo ao destinatário validar a autenticidade.
- **SPF:** Sender Policy Framework: Registro DNS do tipo TXT que publica a lista autorizada de endereços IP autorizados a enviar e-mails em nome de determinado domínio.
- **DMARC:** Domain-based Message Authentication, Reporting, and Conformance: Política que define o que fazer com e-mails que falharem no SPF ou DKIM (none, quarantine ou reject) e gera relatórios.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?

- A)** BEC / CEO fraud (fraude do CEO)
- B)** Whaling
- C)** Vishing
- D)** Tailgating

2. Um atacante envia e-mails direcionados a executivos específicos com informações personalizadas da empresa. Que técnica de engenharia social é essa?

- A) Vishing**
- B) Whaling**
- C) Spam**
- D) Pharming**

3. Um funcionário recebe ligação de alguém se passando por suporte técnico solicitando senha para 'atualização do sistema'. Que técnica é essa?

- A) Vishing**
- B) Pretexting**
- C) Baiting**
- D) Tailgating**

4. Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:

- A) Escassez**
- B) Autoridade + urgência**
- C) Prova social**
- D) Reciprocidade**

5. Cenário corporativo (Phishing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Whaling = phishing mirando executivo (spear phishing de whale)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Substituir controles técnicos preventivos por termos de adesão informais**
- C) Permitir acesso compartilhado entre administradores com credenciais genéricas**
- D) Implementar a solução correspondente: Whaling = phishing mirando executivo (spear phishing de whale)...**

6. Cenário corporativo (Phishing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Vishing = phishing por VOZ; SMiShing = por SMS'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Vishing = phishing por VOZ; SMiShing = por SMS...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Phishing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'SPF/DKIM/DMARC: o trio de autenticação de remetente de email'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: SPF/DKIM/DMARC: o trio de autenticação de remetente de email...

8. Cenário corporativo (Phishing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'C-level executives target' = whaling'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'C-level executives target' = whaling...

9. Cenário corporativo (Phishing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'phishing by voice call' = vishing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'phishing by voice call' = vishing...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Phishing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'email urgente se passando pelo CFO pedindo transferência' = whaling/BEC — não phishing genérico.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário típico: 'email urgente se passando pelo CFO pedindo transferência' ...

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — BEC / CEO fraud (fraude do CEO).

✓ **Por que está certa:** A alternativa correta é 'BEC / CEO fraud (fraude do CEO)'. Business Email Compromise (BEC) é uma categoria de ataque de engenharia social em que o atacante se passa por um executivo de alto escalão (como o CEO) ou por um parceiro de negócios confiável para induzir funcionários a realizar transferências financeiras não autorizadas ou divulgar informações confidenciais. No caso descrito, o golpista envia um e-mail fraudulento se passando pelo CEO e ordena uma transferência urgente ao setor financeiro. Isso se enquadra perfeitamente na definição de BEC, que é reconhecida pela CompTIA como um vetor de ataque baseado em impersonação e engenharia social. A variante específica em que o CEO é personificado é chamada de CEO fraud. Portanto, a opção 'BEC / CEO fraud (fraude do CEO)' é a que melhor descreve o ataque.

✗ **Por que as outras estão erradas:**

- *Whaling*: Whaling é um tipo de ataque de phishing direcionado especificamente a executivos de alto nível (como CEOs, CFOs, etc.). O objetivo é obter informações confidenciais ou acesso a sistemas críticos por meio de e-mails fraudulentos que se passam por fontes confiáveis. No entanto, no cenário descrito, o atacante não está mirando o CEO, mas sim se passando por ele para enganar o setor financeiro. Portanto, whaling não é o termo correto, pois descreve o alvo (o executivo) e não o modus operandi de impersonação do CEO para fraudar subordinados.
- *Vishing*: Vishing é a prática de engenharia social realizada por meio de chamadas telefônicas (voice phishing), onde o atacante se passa por uma entidade confiável para obter informações sensíveis, como senhas ou dados financeiros. No enunciado, o ataque ocorre por e-mail, não por telefone. Portanto, vishing não se aplica ao canal utilizado. Além disso, o vishing não envolve necessariamente a personificação do CEO para ordenar transferências, mas sim ligações fraudulentas em geral.
- *Tailgating*: Tailgating é uma técnica de acesso físico não autorizado em que uma pessoa segue outra em uma área restrita sem se autenticar, geralmente explorando a cortesia ou distração do funcionário autorizado. Não tem relação com ataques de engenharia social por e-mail ou fraudes financeiras. O cenário descreve um ataque cibernético baseado em e-mail fraudulento, não uma invasão física. Portanto, tailgating é completamente inadequado para a situação.

2) B — Whaling.

✓ **Por que está certa:** A técnica descrita é **Whaling**, uma forma especializada de spear phishing direcionada a executivos de alto escalão (CEOs, CFOs, diretores). O atacante realiza reconhecimento prévio para obter informações personalizadas da empresa e do alvo, como nome, cargo, projetos em andamento, fornecedores, etc., e as utiliza para compor uma mensagem altamente convincente. O objetivo pode ser obter credenciais, autorizar transferências financeiras fraudulentas (BEC – Business Email Compromise) ou instalar malware. No syllabus da CompTIA Security+ (SY0-701), whaling é explicitamente listado como um tipo de engenharia social baseada em phishing, distinguindo-se por seu alvo de alto perfil e pelo alto grau de personalização.

✗ **Por que as outras estão erradas:**

- *Vishing*: Vishing (voice phishing) é a prática de enganar vítimas por meio de chamadas telefônicas ou mensagens de voz, muitas vezes simulando instituições financeiras, suporte técnico ou órgãos governamentais. O atacante usa a interação verbal para extrair informações sensíveis ou induzir a vítima a realizar ações, como fornecer senhas ou instalar software remoto. No cenário descrito, o vetor é e-mail direcionado a executivos, não uma chamada telefônica. Portanto, vishing não se aplica porque o meio de comunicação e a dinâmica da abordagem são distintos.
- *Spam*: Spam refere-se ao envio massivo e indiscriminado de mensagens eletrônicas não

solicitadas, geralmente com fins publicitários ou para disseminar malware em larga escala. Não há personalização ou direcionamento a um público específico; o objetivo é atingir o maior número possível de destinatários. No caso em questão, os e-mails são meticulosamente direcionados a executivos específicos e contêm informações personalizadas da empresa, o que caracteriza um ataque direcionado (spear phishing/whaling) e não spam. A ausência de direcionamento e personalização torna o spam inadequado para descrever a técnica.

- **Pharming:** Pharming é uma técnica que redireciona o tráfego de um site legítimo para um site falso, explorando vulnerabilidades no DNS (envenenamento de cache) ou modificando o arquivo hosts da vítima. O usuário acredita estar acessando o site correto, mas é levado a uma página fraudulenta que captura credenciais ou distribui malware. Diferentemente do whaling, o pharming não envolve envio de e-mails personalizados; ele depende de manipulação de infraestrutura de resolução de nomes ou de configurações locais. No enunciado, a ação é um e-mail direcionado, não um redirecionamento de tráfego web, logo pharming não se aplica.

3) A — Vishing.

✓ **Por que está certa:** A alternativa correta é 'Vishing'. Vishing é a combinação de 'voice' e 'phishing', ou seja, engenharia social realizada por meio de chamadas telefônicas (VoIP ou rede telefônica tradicional). No cenário descrito, o atacante se passa por suporte técnico para obter a senha da vítima, caracterizando exatamente um ataque de vishing. A CompTIA Security+ classifica vishing como um ataque de engenharia social baseado em voz, onde a interação em tempo real aumenta a pressão psicológica e a credibilidade percebida. O objetivo é induzir a vítima a revelar credenciais ou executar ações prejudiciais.

✗ Por que as outras estão erradas:

- **Pretexting:** Pretexting é a criação de um cenário ou pretexto falso para obter informações. Embora o atacante no enunciado use um pretexto (falso suporte técnico), o vetor principal é o telefone. Pretexting é um elemento comum em muitos ataques de engenharia social, incluindo vishing, phishing e smishing. A alternativa é incorreta porque não especifica o canal telefônico, que é a característica definidora do vishing. Em termos técnicos, pretexting é a técnica de construção da história, enquanto vishing é o meio de entrega via voz.
- **Baiting:** Baiting envolve deixar um dispositivo físico (como um pendrive infectado) ou uma isca digital para que a vítima o utilize, explorando a curiosidade. Não há relação com chamadas telefônicas ou solicitação direta de senha por voz. A alternativa é incorreta porque descreve um ataque que depende de ação física ou interação com mídia removível, não de interação verbal em tempo real.
- **Tailgating:** Tailgating é uma técnica de acesso físico não autorizado em que o atacante segue um funcionário autorizado através de uma porta segura sem se autenticar. Não envolve telefone, engenharia social verbal ou obtenção de senha. A alternativa é incorreta porque pertence à categoria de ataques físicos, enquanto o cenário descreve um ataque remoto de engenharia social por voz.

4) B — Autoridade + urgência.

✓ **Por que está certa:** A alternativa correta é 'Autoridade + urgência'. A engenharia social explora vieses cognitivos e princípios psicológicos para manipular vítimas. No cenário, o golpista se passa por suporte de TI, o que invoca o princípio da autoridade (a vítima tende a obedecer a figuras de autoridade). Além disso, ele cria um senso de urgência para pressionar a vítima a agir rapidamente, sem pensar criticamente. A combinação de autoridade e urgência é uma tática clássica de engenharia social, reconhecida pela CompTIA. Portanto, a opção 'Autoridade + urgência' descreve com precisão os princípios explorados.

✗ Por que as outras estão erradas:

- *Escassez*: Escassez é um princípio de persuasão que explora a percepção de que recursos são limitados, criando uma sensação de que a oportunidade pode ser perdida se não agir imediatamente. No cenário, não há menção a recursos escassos ou ofertas limitadas. O golpista não está oferecendo algo em quantidade limitada, mas sim se passando por autoridade e criando urgência. Portanto, escassez não é o princípio aplicável.
- *Prova social*: Prova social é a tendência de as pessoas seguirem o comportamento dos outros, assumindo que ações tomadas por muitos são corretas. No ataque descrito, não há menção a outras pessoas fazendo o mesmo ou endossando a ação. O golpista não usa a ideia de que 'todos estão fazendo' para convencer a vítima. Portanto, prova social não é o princípio explorado.
- *Reciprocidade*: Reciprocidade é o princípio de que as pessoas se sentem obrigadas a retribuir um favor ou concessão. No cenário, o golpista não oferece nada primeiro para depois pedir a senha; ele simplesmente se passa por suporte e cria urgência. Não há troca de favores. Portanto, reciprocidade não se aplica.

5) D — Implementar a solução correspondente: Whaling = phishing mirando executivo (spear phishing de whale)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Phishing): Whaling = phishing mirando executivo (spear phishing de whale).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) C — Implementar a solução correspondente: Vishing = phishing por VOZ; SMiShing = por SMS....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Phishing): Vishing = phishing por VOZ; SMiShing = por SMS.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: SPF/DKIM/DMARC: o trio de autenticação de remetente de email....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Phishing): SPF/DKIM/DMARC: o trio de autenticação de remetente de email.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: 'C-level executives target' = whaling....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Phishing): 'C-level executives target' = whaling.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: 'phishing by voice call' = vishing....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Phishing): 'phishing by voice call' = vishing.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: Cenário típico: 'email urgente se passando pelo CFO pedindo transferência'

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Phishing): Cenário típico: 'email urgente se passando pelo CFO pedindo transferência' = whaling/BEC — não phishing genérico..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.